IT GOVERNANCE

Suggested Answers
March-April 2024

Answer to the Question# 1(a):

The National ICT Policy, 2009 aims to ensure quality IT subject teachers outside Dhaka specifies as action items providing special incentive for IT teachers in cities to go to regional colleges (on short-term deputation) and providing special privilege for local ICT professionals/ICT teachers to stay in their home districts. In order to disseminate IT education across the country and make it more affordable to poor students the National ICT Policy, 2009 specifies as action item introducing ICT undergraduate programme at the district level colleges under National University (at least one college at every district). The Ministry of Education, University Grants Commission of Bangladesh, and National University are the primary actors in this regard.

Answer to the Question# 1(b):

As per the the Information & Communication Technology Act, 2006 the conditions under which an electronic record is attributed to the originator are the following:

i. An electronic record was sent by the originator himself.
ii. An electronic record was sent by a person who had the authority to act on behalf of the originator in respect of that electronic record.
iii. An electronic record was sent by an information system programmed by or on behalf of the originator to operate automatically.

Answer to the Question# 1(c):

i. The Web server reads the user's web browser and determines the operating system, browser name, version number, Internet address, and other information.
ii. The server transmits a tiny text file with user identification information called a cookie, which the user's browser receives and stores on the user's computer hard drive.
iii. When the user returns to the website, the server requests the contents of any cookie it deposited previously in the user's computer.
iv. The Web server reads the cookie, identifies the visitor, and calls up data on the user.

Answer to the Question# 2(a):

Difference Based On	Management Information Systems	Decision Support Systems
Decision support provided	Provide information about the performance of the organization	Provide information and decision support techniques to analyze specific problems or opportunities
Information form and frequency	Periodic, exception, demand, and push responses reports and responses	Interactive inquiries and responses
Information format	Prespecified, fixed format	Ad hoc, flexible, and adaptable format
Information processing methodology	Information produced by extraction and manipulation of business data	Information produced by analytical modeling of business data

Answer to the Question# 2(b):

Neural networks (NN) are computational systems inspired by the structure and function of the human brain. They consist of interconnected processing elements called neurons, organized in layers. Each neuron receives input signals, processes them using an activation function, and generates an output signal. Similar to the human brain, NNs operate in parallel and dynamically interact, allowing them to learn from data.

For example, a neural network can be trained to learn credit characteristics that result in good or bad loans. Developers of a credit evaluation neural network could provide it with data from many examples of credit applications and loan results to process, with opportunities to adjust the signal strengths between its neurons. The neural network would continue to be trained until it demonstrated a high degree of accuracy in correctly duplicating the results of recent cases. At that point, it would be trained enough to begin making credit evaluations of its own.

Answer to the Question# 2(c):

Expert systems: Expert systems are computer-based information systems designed to capture and mimic the expertise of human experts in a specific domain. They operate by interacting with users to solve problems, asking questions, analyzing data, and providing recommendations or solutions based on their programmed knowledge base. These systems excel in problem-solving within a narrow domain, offering benefits such as speed, consistency, and the ability to leverage the knowledge of multiple experts without succumbing to fatigue or distraction.

Limitations: The major limitations of expert systems arise from their limited focus, inability to learn, maintenance problems, and developmental cost. Expert systems excel only in solving specific types of problems in a limited domain of knowledge. They fail miserably in solving problems requiring a broad knowledge base and subjective problem

Limitation Mitigation: Careful domain selection ensures that expert systems are deployed in areas where their strengths align with the problem at hand. Continuous improvement processes, including regular updates to the knowledge base, help ensure the relevance and accuracy of expert system outputs over time. Providing comprehensive training and education to users and stakeholders on the capabilities and limitations of expert systems promotes effective utilization and informed decision-making. Collaborating with human experts in the development and implementation of expert systems enhances their effectiveness by providing oversight, validation, and context to system outputs.

Answer to the Question# 2(d):

In the context of blockchain technology, a "smart contract" is a self-executing contract with the terms of the agreement between buyer and seller directly written into lines of code. The code and the agreements exist on a decentralized blockchain network. Smart contracts facilitate, verify, and enforce the negotiation or performance of a contract, without the need for intermediaries.

Answer to the Question# 2(e):

There are four segments in FinTechs. The segments and subsegments are given below:

1. Financing: (a. Crowdfunding - Donation-Based Crowdfunding, Reward-Based Crowdfunding, Crowdinvesting, Crowdlending and b. Credit and Factoring)
2. Asset Management: (a. Social Trading, b. Robo-Advice, c. Personal Financial Management and d. Investment and Banking)
3. Payments: (a. Alternative Payment Methods, b. Blockchains and Cryptocurrencies and c. Other FinTechs)
4. Other FinTechs: (a. Insurance, b. Search Engines and Comparison Sites, c. Technology, IT, and Infrastructure and d. Other FinTechs)

Answer to the Question# 3(a):

Use cases:
COBIT: Risk
COSO: Risk
ITIL: service and operations
CMMI: software engineering, hardware development, service delivery, and purchasing.
FAIR: assessing operational and cyber security risks
Factors:

- Corporate culture
- Whether a particular framework seems like a natural fit for the organization
- Whether the framework resonates with the stakeholders.

Answer to the Question# 3(b):

IoT: IoT stands for Internet of Things, which is a network of physical objects that can communicate with each other and with the internet.
Smart Products: Smart products are a subset of IoT devices that have some form of intelligence or learning capability.
Advantages of X over Y:

- Task automation
- Better optimization of resources
- Better detection of hazards
- Greater reliability

- Easily enable new features to products

Answer to the Question# 3(c):

COMPETITIVE FORCE	IMPACT OF THE INTERNET
Substitute products or services	Enables new substitutes to emerge with new approaches to meeting needs and performing functions
Customers' bargaining power	Availability of global price and product information shifts bargaining power to customers
Suppliers' Bargaining Power	Procurement over the Internet tends to raise bargaining power over suppliers; suppliers can also benefit from reduced barriers to entry and from the elimination of distributors and other intermediaries standing between them and their users
Threat of new entrants	Internet reduces barriers to entry, such as the need for a sales force, access to channels, and physical assets; it provides a technology for driving business processes that makes other things easier to do
Positioning and rivalry among existing competitors	Widens the geographic market, increasing the number of competitors and reducing differences among competitors; makes it more difficult to sustain operational advantages; puts pressure to compete on price

Answer to the Question# 3(d):

I have to ask the following three questions:

1. What is the structure of the industry in which the firm is located?
2. What are the business, firm, and industry value chains for this particular firm?
3. Have we aligned IT with our business strategy and goals?

Answer to the Question# 4(a):

Spyware are malicious software. These small programs install themselves surreptitiously on computers to monitor user web-surfing activity and serve up advertising. Thousands of forms of spyware have been documented. Some forms of spyware are especially nefarious. Keyloggers record every keystroke made on a computer to steal serial numbers for software, to launch Internet attacks, to gain access to e-mail accounts, to obtain passwords to protected computer systems, or to pick up personal information such as credit card or bank account numbers. Other spyware programs reset web browser home pages, redirect search requests, or slow performance by taking up too much memory.

Answer to the Question# 4(b):

Internet vulnerabilities have turned entire nation-states into easy targets for politically motivated hacking to conduct sabotage and espionage. Cyberwarfare is a state-sponsored activity designed to cripple and defeat another state or nation by penetrating its computers or networks to cause damage and disruption. Cyberwarfare also includes defending against these types of attacks. Cyberwarfare is more complex than conventional warfare. Although many potential targets are military, a country's power grids, financial systems, and communications networks can also be crippled. Non-state actors such as terrorists or criminal groups can mount attacks, and it is often difficult to tell who is responsible. Nations must constantly be on the alert for new malware and other technologies that could be used against them, and some of these technologies developed by skilled hacker groups are openly for sale to interested governments.

Preparations for cyberwarfare attacks have become much more widespread, sophisticated, and potentially devastating. In the starting decade of this century, foreign hackers stole source code and blueprints to the oil and water pipelines and power grids. Over the years, hackers have stolen plans for missile tracking systems, satellite navigation devices, surveillance drones, and leading-edge jet fighters.

Answer to the Question# 4(c):

We tend to think the security threats to a business originate outside the organization. In fact, company insiders pose serious security problems. Employees have access to privileged information, and in the presence of sloppy internal security procedures, they are often able to roam throughout an organization's systems without

leaving a trace. Studies have found that user lack of knowledge is the single greatest cause of network security breaches. Many employees forget their passwords to access computer systems or allow coworkers to use them, which compromises the system.

Malicious intruders seeking system access sometimes trick employees into revealing their passwords by pretending to be legitimate members of the company in need of information. This practice is called social engineering. Both end users and information systems specialists are also a major source of errors introduced into information systems. End users introduce errors by entering faulty data or by not following the proper instructions for processing data and using computer equipment. Information systems specialists may create software errors as they design and develop new software or maintain existing programs.

Answer to the Question# 4(d):

It's important to remember that cybersecurity is a business-wide issue and not just a technology risk. Since many opportunities for IoT will arise through technological integration and collaboration, which will continue to increase in complexity — this complexity breeds risk.

Traditional proven risk management models have their origins and wisdom still focused in a world where the organization owns and possesses most, if not all, of the data assets flowing through the systems. The increasing use of the internet and mobile working means that the boundary of the enterprise is disappearing: and as a result, the risk landscape also becomes unbounded. With most of today's business being done outside the organization's defensive fence, it is vital for organizations to be able to communicate with their business partners — and to do this they must create holes in the fence. As a result, a cybersecurity system should also include the organization's broader network, including clients, customers, suppliers/vendors, collaborators, business partners and even their alumni — together called the business ecosystem.

Answer to the Question# 5(a):

1. **Inheritance:** The ability of one object to inherit the characteristics of a higher-order object.
2. **Modularity:** The extent to which a program is designed as a series of interlinked yet stand-alone modules.
3. **Polymorphism:** The ability of an object to behave differently depending on the conditions in which its behavior is invoked.
4. **Encapsulation:** Concealing all of the characteristics associated with a particular object inside the object itself.

Answer to the Question# 5(b):

1: **Quality**
Is it bug-free, or does it have many errors in its program code?
2. **Efficiency**
Is the software a well-developed system of program code that does not use much CPU time, memory capacity, or disk space?
3. **Flexibility**
How adaptable is the software to changes in business requirements?
4. **Security**
Does it provide control procedures for errors, malfunctions, and improper use?
5. **Connectivity**
Is it Web-enabled so it can easily access the Internet, intranets, and extranets, on its own, or by working with Web browsers or other network software?
6. **Maintenance**
Will new features and bug fixes be easily implemented by our own software developers?
7. **Documentation**
Is the software well-documented, including comprehensive manuals and help screens?
8. **Hardware**
Does existing hardware have the features required to best use this software?

Answer to the Question# 5(c):

- **Acquisition**
  Evaluate and acquire necessary hardware and software resources and information system services.
- **Software Development**
  Develop any software that will not be acquired externally as software packages. Make any necessary modifications to software packages that are acquired.
- **Data Conversion**
  Convert data in company databases to new data formats and subsets required by newly installed software.
- **Training**
  Educate and train management, end users, customers, and other business stakeholders. Use consultants or training programs to develop user competencies.
- **Testing**
  Test and make necessary corrections to the programs, procedures, and hardware used by a new system.
- **Documentation**
  Record and communicate detailed system specifications, including procedures for end users and Information System personnel and examples of input screens and output displays and reports.
- **Conversion**
  Convert from the use of a present system to the operation of a new or improved system.

Answer to the Question# 5(d):

(1) Investigation
(2) Analysis
(3) Design
(4) Implementation
(5) Maintenance.

Answer to the Question# 6(a):

The IS auditor should understand that other considerations, such as the results of periodic risk assessments, changes in the application of technology, and evolving privacy issues and regulatory requirements, may impact the overall approach to the audit. The IS auditor should also take into consideration system implementation/upgrade deadlines, current and future technologies, requirements from business process owners, and IS resource limitations. When planning an audit, the IS auditor must have an understanding of the overall environment under review. This should include a general understanding of the various business practices and functions relating to the audit subject, as well as the types of information systems and technology supporting the activity. For example, the IS auditor should be familiar with the regulatory environment in which the business operates.

Answer to the Question# 6(b):

The framework for the ISACA IS Audit and Assurance Standards provides for multiple levels of documents:

• Standards define mandatory requirements for IS audit and assurance and reporting.

• Guidelines provide guidance in applying IS Audit and Assurance Standards. The IS auditor should consider them in determining how to achieve implementation of the above standards, use professional judgment in their application and be prepared to justify any departure from the standards.

• Tools and techniques provide examples of processes an IS auditor might follow in an audit engagement. The tools and techniques documents provide information on how to meet the standards when completing IS auditing work, but do not set requirements.

There are three categories of standards and guidelines—general, performance and reporting:

General— The guiding principles under which the IS assurance profession operates. They apply to the conduct of all assignments, and deal with the IS audit and assurance professional's ethics, independence, objectivity and due care as well as knowledge, competency and skill.

Performance— Deal with the conduct of the assignment, such as planning and supervision, scoping, risk and materiality, resource mobilization, supervision and assignment management, audit and assurance evidence, and the exercising of professional judgment and due care.

Reporting— Address the types of reports, means of communication and the information communicated.

Answer to the Question# 6(c):

COBIT 5 offers a comprehensive framework that aids enterprises in achieving their objectives for the governance and management of enterprise IT (GEIT). It helps organizations maximize value from IT by balancing the realization of benefits with the optimization of risk levels and resource use. COBIT 5 ensures IT is governed and managed holistically across the entire enterprise, encompassing all business and IT functions, and addressing the IT-related interests of both internal and external stakeholders. It is a versatile framework applicable to enterprises of all sizes, whether commercial, not-for-profit, or public sector.
COBIT 5 is based on the following five key principles for governance and management of enterprise IT:

- Principle 1: Meeting Stakeholder Needs.
- Principle 2: Covering the Enterprise End-to-End.
- Principle 3: Applying a Single, Integrated Framework.
- Principle 4: Enabling a Holistic Approach.
- Principle 5: Separating Governance from Management.

Answer to the Question# 6(d):

There are many risk assessment methodologies, computerized and noncomputerized, from which the IS auditor may choose. These range from simple classifications based on the IS auditor's judgment of high, medium and low to complex scientific calculations that provide a numeric risk rating. The scoring system risk assessment approach is useful in prioritizing audits based on an evaluation of risk factors. The system considers variables such as technical complexity, level of control procedures in place and level of financial loss. These variables may or may not be weighted. The risk values are then compared to each other, and audits are scheduled accordingly.

Answer to the Question# 6(e):

Auditing is an ongoing process. The IS auditor is not effective if audits are performed and reports issued, but no follow-up is conducted to determine whether management has taken appropriate corrective actions. The follow-up program in IS auditing is an essential process to ensure that the recommendations and corrective actions identified during an audit are implemented effectively and timely. Although IS auditors who work for external audit firms may not necessarily follow this process, they may achieve these tasks if agreed to by the audited entity.

The timing of the follow-up will depend on the criticality of the findings and would be subject to the IS auditor's judgment. The results of the follow-up should be communicated to appropriate levels of management. The level of the IS auditor's follow-up review will depend on several factors. In some instances, the IS auditor may merely need to inquire as to the current status. In other instances, the IS auditor who works in an internal audit function may have to perform certain audit steps to determine whether the corrective actions agreed on by management have been implemented.

---The End---